

Detailed Scan Analysis Report

1. Nmap Findings — Detailed Analysis

Target: Metasploitable 2

Target IP: 192.168.23.130

Assessment Tool: Nmap

Assessment Type: TCP Port and Service Enumeration

Finding NMAP-01 — FTP Service

Port: 21/TCP

Service: FTP

Version: vsftpd 2.3.4

Observation:

The Nmap scan identifies an FTP service running on TCP port 21. The service is associated with **vsftpd 2.3.4**, an intentionally vulnerable version included in Metasploitable 2.

Security Assessment:

FTP transmits authentication information and data without encryption. In addition, this particular version of vsftpd is historically associated with a well-known backdoor vulnerability.

The service should therefore be treated as a significant security risk. The assessment should also determine whether anonymous FTP access is enabled and whether the service is actually required.

Potential Risk:

An attacker who can reach the service may potentially exploit weaknesses in the FTP implementation and, depending on the vulnerability and configuration, obtain unauthorized access to the system.

Recommendation:

- Disable FTP if it is not required.
- If file transfer is necessary, use a secure alternative such as SFTP.
- Restrict FTP access through firewall rules.

- Disable anonymous access where unnecessary.
- Upgrade vulnerable software to a supported version.
- Monitor authentication and FTP activity.

Priority: Critical / High

Finding NMAP-02 — SSH Service

Port: 22/TCP

Service: SSH

Version: OpenSSH 4.7p1 Debian 8ubuntu1

Observation:

SSH is exposed on TCP port 22 and provides remote command-line access to the server.

Security Assessment:

SSH is normally an appropriate secure administration protocol, but the detected version is significantly outdated. An exposed legacy SSH implementation can increase the risk of exploitation and may contain vulnerabilities that have been corrected in later releases.

Additionally, weak passwords or unrestricted remote access could make SSH susceptible to password-guessing attacks.

Potential Risk:

Compromise of SSH credentials could provide an attacker with authenticated remote access to the target system.

Recommendation:

- Upgrade OpenSSH to a supported version.
- Use strong authentication credentials.
- Prefer SSH keys over password-only authentication.
- Disable unnecessary accounts.
- Restrict SSH access to authorized administration networks.
- Disable root login where appropriate.
- Monitor failed authentication attempts.

Priority: High

Finding NMAP-03 — Telnet Service

Port: 23/TCP

Service: Telnet

Version: Linux telnetd

Observation:

A Telnet service is exposed on TCP port 23.

Security Assessment:

Telnet is an insecure remote-administration protocol because authentication credentials and session information can be transmitted without adequate encryption.

An attacker capable of monitoring the network may potentially capture credentials and other sensitive information.

Potential Risk:

Credential disclosure and unauthorized remote access.

Recommendation:

- Disable Telnet.
- Replace Telnet with SSH.
- Restrict remote administration to trusted networks.
- Remove unnecessary Telnet-related packages and services.
- Monitor the system for legacy administrative protocols.

Priority: High

Finding NMAP-04 — SMTP Service

Port: 25/TCP

Service: SMTP

Version: Postfix smtpd

Observation:

An SMTP mail service is exposed on TCP port 25.

Security Assessment:

An SMTP service is not necessarily vulnerable simply because port 25 is open. However, an exposed mail service should be carefully configured to prevent unauthorized relay, information disclosure, and abuse.

The service version and configuration should be reviewed against current security requirements.

Potential Risk:

Depending on configuration, weaknesses may allow unauthorized mail relay, service abuse, information disclosure, or exploitation of vulnerable software.

Recommendation:

- Upgrade the mail server software.
- Disable open relay.
- Restrict SMTP access where appropriate.
- Implement appropriate authentication controls.
- Configure anti-spam and monitoring mechanisms.
- Use encrypted SMTP communication where applicable.

Priority: Medium / High

Finding NMAP-05 — HTTP Web Server

Port: 80/TCP

Service: HTTP

Version: Apache httpd 2.2.8

Observation:

An HTTP web server is accessible on TCP port 80.

Security Assessment:

The detected Apache version is outdated. An exposed web server can also provide access to vulnerable applications, administrative interfaces, default content, or other services hosted by the server.

Because Metasploitable 2 is intentionally vulnerable, the web server should be considered a major component of the attack surface.

Potential Risk:

Potential risks include exploitation of vulnerable web applications, information disclosure, unauthorized access, and compromise through vulnerable server software.

Recommendation:

- Upgrade Apache to a supported release.
- Remove unnecessary web applications and default content.
- Disable unnecessary modules.
- Apply security patches.
- Use HTTPS for sensitive communications.
- Restrict administrative interfaces.
- Perform regular web-application security assessments.

Priority: High

Finding NMAP-06 — RPC Service

Port: 111/TCP

Service: RPCbind / SunRPC

Version: rpcbind

Observation:

RPC-related services are exposed through TCP port 111.

Security Assessment:

RPC services can expose information about additional services running on the system and may increase the remotely accessible attack surface.

On a production server, RPC should only be exposed where operationally necessary.

Potential Risk:

Information disclosure and increased attack surface. Depending on associated RPC services, additional vulnerabilities may become remotely accessible.

Recommendation:

- Disable RPC services when unnecessary.
- Restrict RPC access using firewall rules.
- Review associated RPC services.

- Prevent exposure to untrusted networks.
- Monitor RPC-related traffic.

Priority: Medium / High

Finding NMAP-07 — SMB Services

Ports: 139/TCP, 445/TCP

Service: NetBIOS/SMB

Version: Samba

Observation:

SMB-related services are accessible through TCP ports 139 and 445.

Security Assessment:

SMB provides network file and resource-sharing functionality. Exposing SMB to untrusted networks can create significant security risks, particularly when combined with outdated Samba implementations, weak authentication, or vulnerable SMB configurations.

Potential Risk:

Potential risks include unauthorized file access, credential attacks, information disclosure, and exploitation of vulnerabilities in the SMB/Samba implementation.

Recommendation:

- Disable SMB if it is not required.
- Restrict ports 139 and 445 to trusted networks.
- Upgrade Samba.
- Remove unnecessary shares.
- Apply strong access controls.
- Disable guest access where unnecessary.
- Audit existing SMB shares and permissions.

Priority: High

Finding NMAP-08 — MySQL Database

Port: 3306/TCP

Service: MySQL

Version: MySQL 5.0.x

Observation:

A MySQL database service is exposed on TCP port 3306.

Security Assessment:

Database services generally should not be directly accessible from untrusted networks. The detected MySQL version is also significantly outdated.

Direct exposure increases the possibility of credential attacks, unauthorized database access, and exploitation of vulnerabilities in the database software.

Potential Risk:

Unauthorized access to databases could result in disclosure, modification, or destruction of sensitive information.

Recommendation:

- Upgrade MySQL to a supported version.
- Restrict port 3306 to authorized application servers.
- Disable remote database access where unnecessary.
- Enforce strong database authentication.
- Remove default or unnecessary accounts.
- Apply least-privilege permissions.
- Encrypt database connections where appropriate.

Priority: High

Finding NMAP-09 — PostgreSQL Database

Port: 5432/TCP

Service: PostgreSQL

Version: PostgreSQL 8.3.x

Observation:

A PostgreSQL database service is exposed on TCP port 5432.

Security Assessment:

The PostgreSQL implementation is outdated and is exposed directly over the network. Database services should generally be restricted to application hosts and authorized administrators.

Potential Risk:

An attacker may attempt credential attacks or exploit weaknesses in the database service to obtain unauthorized access.

Recommendation:

- Upgrade PostgreSQL.
- Restrict port 5432 using firewall rules.
- Remove unnecessary database accounts.
- Enforce strong authentication.
- Apply least-privilege access.
- Disable remote access where not required.

Priority: High

2. Nmap Overall Security Assessment

The Nmap scan demonstrates that the Metasploitable 2 server has a **large exposed attack surface**.

The major concerns are:

Port	Service	Security Concern	Priority
21	FTP	Insecure/outdated FTP service	Critical/High
22	SSH	Legacy SSH implementation	High
23	Telnet	Clear-text remote administration	High
25	SMTP	Mail service exposure/configuration	Medium/High
80	HTTP	Outdated web server/application exposure	High
111	RPC	Additional remotely accessible services	Medium/High
139/445	SMB	Network file-sharing exposure	High
3306	MySQL	Exposed legacy database	High

Port	Service	Security Concern	Priority
5432	PostgreSQL	Exposed legacy database	High

Overall Nmap Assessment: High Risk

The combination of numerous exposed services, legacy software versions, insecure protocols, and vulnerable applications significantly increases the attack surface.

3. Nessus Findings — Detailed Analysis

Target: 192.168.23.130

Scanner: Nessus

Target Platform: Metasploitable 2

Important: Nessus plugin names, severity ratings, evidence, and port associations should be copied from your actual Nessus report. The following is a report-ready analysis of the major findings commonly associated with Metasploitable 2.

Finding NESSUS-01 — vsftpd 2.3.4 Backdoor Vulnerability

Vulnerability: vsftpd 2.3.4 Backdoor Command Execution

Severity: Critical

Affected Service: FTP / vsftpd

Port: 21/TCP

Evidence:

Nessus identifies the FTP service as running **vsftpd 2.3.4**, a version associated with a known backdoor vulnerability.

Impact:

Successful exploitation may allow unauthorized command execution on the target system. Because the affected service is network accessible, exploitation can potentially result in complete compromise of the host.

Remediation:

- Immediately remove the vulnerable vsftpd version.
- Upgrade to a supported and trusted release.

- Disable FTP if it is unnecessary.
- Restrict access to the FTP service.
- Investigate the system for signs of unauthorized modification if this were a production host.

Priority: Critical

Finding NESSUS-02 — Outdated OpenSSH

Vulnerability: Outdated OpenSSH Version

Severity: High

Affected Service: SSH

Port: 22/TCP

Evidence:

Nessus detects an older OpenSSH implementation exposed on TCP port 22.

Impact:

Legacy SSH software may contain known vulnerabilities and weaknesses. Combined with weak credentials or unrestricted network exposure, this may increase the likelihood of unauthorized remote access.

Remediation:

- Upgrade OpenSSH.
- Apply current operating-system security updates.
- Disable weak authentication mechanisms.
- Use SSH keys where appropriate.
- Restrict SSH access to trusted administration networks.

Priority: High

Finding NESSUS-03 — Telnet Service Detected

Vulnerability: Cleartext Telnet Service

Severity: High

Affected Service: Telnet

Port: 23/TCP

Evidence:

Nessus identifies a Telnet service listening on TCP port 23.

Impact:

Telnet does not provide adequate confidentiality for remote administration. Credentials and session information may be exposed to network monitoring.

Remediation:

- Disable Telnet.
- Replace Telnet with SSH.
- Restrict administrative access through firewall policies.
- Audit existing accounts and authentication credentials.

Priority: High

Finding NESSUS-04 — Apache Web Server Outdated

Vulnerability: Apache HTTP Server Outdated / Multiple Vulnerabilities

Severity: High

Affected Service: Apache HTTP Server

Port: 80/TCP

Evidence:

Nessus identifies an outdated Apache HTTP Server version on the target.

Impact:

Known vulnerabilities in legacy web-server software may allow information disclosure, denial of service, or potentially unauthorized code execution depending on the specific vulnerability and configuration.

Remediation:

- Upgrade Apache to a supported version.
- Apply all applicable security patches.
- Remove unnecessary modules.
- Remove default and vulnerable applications.

- Configure HTTPS.
- Restrict administrative interfaces.

Priority: High

Finding NESSUS-05 — Samba/SMB Vulnerabilities

Vulnerability: Vulnerable Samba/SMB Service

Severity: High

Affected Service: Samba / SMB

Ports: 139/TCP and 445/TCP

Evidence:

Nessus identifies SMB/Samba services accessible through TCP ports 139 and 445 and detects legacy software/configuration associated with known vulnerabilities.

Impact:

Successful exploitation or unauthorized access to SMB may result in disclosure or modification of shared files and, depending on the specific vulnerability, potentially remote compromise of the system.

Remediation:

- Upgrade Samba.
- Disable SMB where unnecessary.
- Restrict TCP 139 and 445 to trusted networks.
- Remove unnecessary shares.
- Disable guest access.
- Review file and share permissions.

Priority: High

Finding NESSUS-06 — MySQL Service Exposed

Vulnerability: MySQL Remote Service / Outdated Database

Severity: High

Affected Service: MySQL

Port: 3306/TCP

Evidence:

Nessus detects MySQL running on TCP port 3306 and identifies the database implementation as a legacy version.

Impact:

An exposed database service can permit unauthorized connection attempts. If weak credentials or vulnerable software are present, an attacker could potentially obtain unauthorized access to databases.

Remediation:

- Upgrade MySQL.
- Restrict TCP 3306 to authorized hosts.
- Disable remote access when unnecessary.
- Remove default accounts.
- Enforce strong authentication.
- Apply least-privilege database permissions.

Priority: High

Finding NESSUS-07 — PostgreSQL Service Exposed

Vulnerability: Outdated PostgreSQL Database

Severity: High

Affected Service: PostgreSQL

Port: 5432/TCP

Evidence:

Nessus identifies PostgreSQL listening on TCP port 5432.

Impact:

An exposed and outdated database service increases the possibility of unauthorized database access and exploitation of known software vulnerabilities.

Remediation:

- Upgrade PostgreSQL.

- Restrict access to authorized systems.
- Use strong authentication.
- Remove unnecessary accounts.
- Apply least privilege.
- Disable external access if the database does not require it.

Priority: High

Finding NESSUS-08 — Multiple Outdated Services

Vulnerability: Multiple Unsupported/Outdated Network Services

Severity: High

Affected Services: FTP, SSH, HTTP, SMB, databases and other network services

Port: Multiple

Evidence:

The Nessus scan identifies several legacy services and software versions operating on the target.

Impact:

Running multiple outdated services significantly increases the probability that one or more publicly documented vulnerabilities can be used to compromise the system.

The risk is compounded because several vulnerable services are simultaneously exposed.

Remediation:

- Establish an asset and software inventory.
- Patch operating-system and application vulnerabilities.
- Remove unsupported software.
- Disable unnecessary services.
- Restrict network exposure.
- Implement vulnerability-management procedures.
- Conduct regular authenticated vulnerability assessments.

Priority: High

4. Nessus Risk Prioritization

The findings can be prioritized as follows:

Priority	Finding	Severity	Recommended Action
1	vsftpd 2.3.4 backdoor	Critical	Disable/remove immediately
2	Other remotely exploitable legacy services	High	Patch/restrict immediately
3	SMB/Samba weaknesses	High	Patch and restrict
4	Outdated Apache	High	Upgrade and harden
5	Telnet	High	Disable and replace with SSH
6	Exposed MySQL	High	Restrict and upgrade
7	Exposed PostgreSQL	High	Restrict and upgrade
8	Legacy SSH	High	Upgrade and harden
9	SMTP exposure	Medium/High	Harden/restrict
10	Informational/configuration findings	Low/Info	Address during hardening

5. Consolidated Risk Analysis

The assessment shows that the target server presents a **high-risk security posture**.

The most important issue is not simply that individual ports are open. The primary concern is the **combination of multiple remotely accessible services and outdated or intentionally vulnerable software**.

For example:

FTP exposure

- vulnerable FTP implementation
- potential unauthorized command execution
- possible system compromise

Similarly:

SMB exposure

- vulnerable/legacy Samba
- unauthorized access or exploitation
- potential compromise

And:

Web server exposure

- outdated Apache/application stack
- web-based attack surface
- potential application/server compromise

This demonstrates why vulnerability assessment should combine **network enumeration with vulnerability scanning** rather than relying on port discovery alone.

6. Recommended Remediation Plan

Immediate Remediation — Critical

1. Remove or disable **vsftpd 2.3.4**.
2. Investigate any system that has been exposed to untrusted networks.
3. Apply operating-system security updates.
4. Remove known vulnerable applications.

Short-Term Remediation — High

1. Disable Telnet.
2. Upgrade OpenSSH.
3. Upgrade Apache.
4. Upgrade Samba.
5. Restrict SMB ports 139/445.
6. Restrict MySQL port 3306.
7. Restrict PostgreSQL port 5432.
8. Remove unnecessary services.
9. Strengthen authentication.

10. Apply least-privilege access controls.

Long-Term Hardening

1. Implement host-based firewall rules.
 2. Segment servers from user networks.
 3. Establish regular patch management.
 4. Perform periodic vulnerability scanning.
 5. Monitor authentication events.
 6. Monitor network services.
 7. Maintain an accurate software inventory.
 8. Remove unsupported software.
 9. Establish secure configuration baselines.
 10. Perform a follow-up Nmap and Nessus scan after remediation.
-

7. Final Assessment Statement

Overall Risk Rating: CRITICAL / HIGH

The vulnerability assessment of Metasploitable 2 (192.168.23.130) identified a broad attack surface consisting of multiple exposed network services, legacy software, insecure protocols, and known vulnerabilities. Nmap provided visibility into the available ports and services, while Nessus provided vulnerability identification and severity classification. The most significant risks involve remotely accessible vulnerable services, particularly the legacy FTP service, SMB/Samba, web services, and exposed database services.

Remediation should begin with Critical findings, followed by High-severity vulnerabilities and unnecessary network services. Services that are not required should be disabled, while required services should be upgraded, securely configured, and restricted to authorized networks.

After remediation, the system should be rescanned using both Nmap and Nessus to verify that the vulnerabilities have been addressed. This establishes a complete assessment cycle of **discovery → vulnerability identification → risk prioritization → remediation → verification**.